RELATÓRIO TÉCNICO / SEGURANÇA

Relatório de Auditoria de Segurança

Portfólio de Carlos Henrique Lopes

Data e escopo	Versão examinada
16/10/2026 / America/Fortaleza	Cinco categorias da skill auditoria-seguranca-codigo
Modo de execução	Observação do código; relatório e fontes estruturadas
Base Git	e8229493d1ffd9e00577c8d71056f0d4adad19c2
Snapshot da aplicação	Árvore de trabalho local após melhorias de SEO e acessibilidade; alterações ainda não publicadas.

0 vulnerabilidades confirmadas

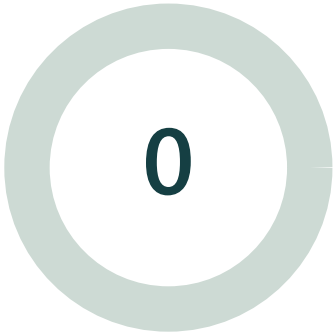
Três categorias não se aplicam à stack atual. Segredos e XSS foram examinados nos fluxos disponíveis. O resultado não significa ausência garantida de vulnerabilidades.

Metodologia: inventário da aplicação, rastreio de entradas e destinos de renderização, verificação do histórico Git local e busca de padrões de credenciais no bundle. Não foram executados ataques contra serviços reais.

O relatório registra a árvore de trabalho após as melhorias autorizadas de SEO e acessibilidade. Nenhuma correção de segurança, issue pública, commit ou push foi executada nesta auditoria.

Resumo executivo

Não foi confirmado fluxo explorável nas cinco categorias avaliadas. A aplicação distribui conteúdo público, sem backend autenticado, banco de dados ou objetos privados por usuário.



Achados confirmados

Contagem por categoria

C1 / Isolamento	0
C2 / Permissões	0
C3 / IDOR	0
C4 / Segredos	0
C5 / XSS	0

Faixas sem preenchimento: nenhum achado.

Severidade	Contagem
Crítica	0
Alta	0
Média	0
Baixa	0
Informativa	0

A rosca fica neutra porque a contagem é zero. Não há fatias artificiais. Pontos fortes e recomendações informativas não entram na contagem de vulnerabilidades.

Paleta de severidade: crítica #B91C1C; alta #EA580C; média #D97706; baixa #2563EB. Pontos fortes #059669; informações e limites em cinza.

Stack e superfície examinada

Linguagem: TypeScript e JavaScript

Frontend: React 19.2.1 / React DOM 19.2.1

Build: Vite 7.2.7 / TypeScript 5.9.3

Estilos: Tailwind CSS e CSS autoral com tokens

Deploy: Netlify, saída estática dist/

Auth: Não existe autenticação de aplicação.

Database: Nenhum banco, ORM ou query builder.

Tenant: Não existe isolamento de tenant/dono porque o conteúdo é público.

Inventário de autorização e objetos

Handlers de backend: 0. Gates de papel autenticado no frontend: 0. Os atributos role encontrados são semântica de acessibilidade; não controlam privilégios.

Controles públicos: Seleção de projeto e galeria, Preferência de tema em localStorage, Pausa da animação, Navegação e cópia do e-mail público.

Corpus atual: 106 arquivos no manifesto, dos quais 53 textuais. Histórico local não raso: 67 commits e 186 blobs textuais examinados. 64 blobs binários históricos não foram decodificados.

Bundle disponível: dist/assets/index-C7slHcQK.js.

Resultado por categoria

Categoria	Estado	Resultado e motivo
C1 / Isolamento de tenant/dono	Não aplicável	Não há banco, queries ou armazenamento de objetos privados. Dados são módulos e arquivos públicos.
C2 / Permissões no servidor	Não aplicável	Nenhum handler de backend ou gate de papel autenticado no frontend. Estados visuais não concedem privilégios.
C3 / IDOR	Não aplicável	Nenhuma rota de leitura/escrita de objeto privado por ID. Os identificadores dos cards apontam a conteúdo público do build.
C4 / Segredos embutidos	Verificado	Nenhum candidato nos arquivos textuais atuais, em 186 blobs textuais históricos e nos bundles JavaScript disponíveis.
C5 / XSS	Protegido nos fluxos revisados	Conteúdo em JSX, tema validado e URLs locais/HTTPS estáticas. Não encontrado fluxo de entrada externa para HTML bruto, eval ou Function.

Tabela de achados detalhados

Severidade	Arquivo:linha	Descrição
Nenhuma	Não aplicável	0 achados confirmados. Não há vulnerabilidade a atribuir a arquivo/linha.

Ausência de banco ou autenticação não é uma falha nesta aplicação pública. Caso essas superfícies sejam adicionadas, as categorias C1, C2 e C3 precisam ser reavaliadas.

Pontos fortes com evidências

PF-01 / src/components/ThemeToggle.tsx

Linha 6 da árvore de trabalho examinada.

```
try { const value = localStorage.getItem('carlos-portfolio-theme');
return value === 'dark' || value === 'light' ? value : null; }
```

Entrada do localStorage limitada aos valores light e dark antes de alterar o tema. Não há interpolação em HTML.

PF-02 / src/sections/Projects.tsx

Linha 9 da árvore de trabalho examinada.

```
return <><p>{project.description}</p>{showTech && <ul className="tags"
aria-label={'Tecnologias de ' + project.title}>{project.tech.map(tech =>
 <li key={tech}>{tech}</li>)}</ul>}
```

Descrições renderizadas em JSX; origem no módulo estático portfolio.ts. Nenhum sink HTML bruto foi encontrado no código autoral.

PF-03 / src/components/ProjectGallery.tsx

Linha 35 da árvore de trabalho examinada.

```
<a href={image.src} target="_blank" aria-describedby="new-tab-hint"
rel="noopener noreferrer" aria-label={`Abrir imagem ${index + 1} de
${title} em tamanho completo`} tabIndex={index === active ? 0 : -1}><img
 src={image.src} alt={
```

URLs de imagens chegam do mapa estático projectImages, utilizado por ProjectModal. Não são construídas a partir de query string, hash ou formulário.

Referências de linha pertencem ao snapshot local desta revisão. Não são linhas de revisões históricas.

Pontos fortes com evidências

PF-04 / src/components/HeroComet.tsx

Linha 63 da árvore de trabalho examinada.

```
if (layer === midpoint.layer) segment?.setAttribute('d',
`M${leading.x.toFixed(2)} ${leading.y.toFixed(2)}
L${trailing.x.toFixed(2)} ${trailing.y.toFixed(2)}`);
```

O atributo SVG d recebe coordenadas numéricas internas, formatadas com toFixed. setAttribute aqui não recebe HTML nem entrada externa.

PF-05 / src/sections/ProjectShowcase.tsx

Linha 14 da árvore de trabalho examinada.

```
const selected = projectCards.find(project => project.id ===
selectedId);
```

A seleção usa um conjunto de projetos públicos definido no build. Não consulta objetos privados nem representa autorização.

PF-06 / index.html

Linha 16 da árvore de trabalho examinada.

```
const theme = preference === 'dark' || preference === 'light' ?
preference : 'light';
```

O inicializador do tema aplica a mesma lista fechada de valores antes do React. O JSON-LD também é literal estático.

Referências de linha pertencem ao snapshot local desta revisão. Não são linhas de revisões históricas.

Limites e observações

1. Revisão local não destrutiva. Não houve exploração de produção, uso de credenciais, login, publicação de issues, commit ou push.

2. A ausência de candidatos em uma busca por padrões não garante ausência de segredos. Segredos ofuscados, divididos, criptografados e fora do repositório podem não ser detectados.

3. Histórico local não raso: 67 commits alcançáveis pelas referências locais disponíveis. Não foram buscados objetos remotos apagados ou inalcançáveis.

4. 64 blobs históricos binários não foram decodificados. Imagens, fontes e PDFs não passaram por OCR ou inspeção de metadados sensíveis. Seus hashes atuais estão no manifesto.

5. Pastas locais ignoradas (work, outputs, node_modules, .netlify), variáveis de ambiente e configurações privadas do provedor estão fora do corpus. O PDF não relacionado e o cache .vite existentes na raiz foram preservados.

6. Bundles JavaScript disponíveis foram examinados por padrões; source maps de produção não estavam disponíveis. Fontes TypeScript/TSX locais foram examinadas diretamente.

7. A classificação de proteção descreve somente os fluxos identificados. O relatório não é certificação nem garantia de segurança integral.

Pontos de atenção, sem classificação de vulnerabilidade

netlify.toml / Informação, não vulnerabilidade confirmada

Não há política CSP declarada neste arquivo versionado. Uma política pode acrescentar defesa em profundidade, mas sua ausência isolada não confirma XSS. Cabeçalhos efetivos do painel/produção não foram auditados.

package-lock.json / Limite de verificação

Versões foram inventariadas. Não foi executada análise completa de CVEs ou da cadeia de dependências; isso é distinto das cinco categorias solicitadas.

Recomendações priorizadas

P1 - se houver expansão / Reauditar antes de adicionar dados privados ou autenticação

Se um backend, banco ou área administrativa for proposto, definir autorização no servidor e validar posse de objetos antes de expor essas operações. As três categorias não aplicáveis hoje deverão ser reavaliadas.

P2 - defesa em profundidade / Avaliar CSP em uma mudança própria

Mapear os recursos necessários e testar uma política que considere os scripts inline de tema e JSON-LD. Não aplicar uma política ampla às cegas nem tratar esta sugestão como correção de XSS confirmado.

P2 - prevenção / Incluir revisão de segredos nas próximas entregas

Executar novamente a varredura sobre fonte, histórico e bundle após mudanças de integrações. Revisar manualmente os arquivos públicos antes de enviar novas capturas ou documentos.

P3 - trabalho separado / Revisar dependências e configurações do provedor

Em escopo específico, consultar advisories das versões instaladas e conferir cabeçalhos, permissões e variáveis no painel da Netlify, sem presumir vulnerabilidade apenas por número de versão.

Reprodução e rastreabilidade

A partir da raiz do repositório, execute:

```
python docs/security-audit/varrer_segredos.py
python docs/security-audit/gerar_relatorio.py
```

O scanner usa somente a biblioteca padrão do Python e o Git. O gerador usa ReportLab. Os dados estruturados e a cobertura registram a revisão humana; executar o scanner ou o gerador não substitui uma nova análise dos fluxos.

SHA-256 do manifesto do snapshot:
6d7d30815b2958502c6fb6cfedf0fe3de542bbfe9fd0d8d502d30f69e9b46d9a

Cobertura por arquivo

Cada categoria e seu motivo estão detalhados em cobertura.json. A tabela compacta abaixo cobre todos os arquivos textuais do manifesto. Assets binários têm hash registrado, com inspeção de conteúdo sensível declarada como não verificada.

T = tenant/dono; A = autorização; I = IDOR; S = segredos; X = XSS. NA = não aplicável; V = verificado por padrões; P = protegido nos fluxos revisados.

Arquivo / linhas	T	A	I	S	X
.gitignore / 34	NA	NA	NA	V	NA
DESIGN_SYSTEM.md / 171	NA	NA	NA	V	NA
README.md / 202	NA	NA	NA	V	NA
eslint.config.js / 24	NA	NA	NA	V	NA
index.html / 103	NA	NA	NA	V	P
netlify.toml / 35	NA	NA	NA	V	NA
package-lock.json / 4181	NA	NA	NA	V	NA
package.json / 39	NA	NA	NA	V	NA
postcss.config.js / 6	NA	NA	NA	V	NA
public/404.html / 3	NA	NA	NA	V	P
public/favicon.svg / 2	NA	NA	NA	V	NA
public/fonts/README.md / 12	NA	NA	NA	V	NA
public/fonts/dm-sans-OFL.txt / 94	NA	NA	NA	V	NA
public/fonts/manrope-OFL.txt / 94	NA	NA	NA	V	NA
public/projects/gallery/sources.json / 89	NA	NA	NA	V	NA
public/publications/sources.json / 33	NA	NA	NA	V	NA
public/robots.txt / 5	NA	NA	NA	V	NA
public/sitemap.xml / 5	NA	NA	NA	V	NA
public/vite.svg / 1	NA	NA	NA	V	NA
scripts/verify-accessibility.mjs / 114	NA	NA	NA	V	NA
scripts/verify-seo.mjs / 37	NA	NA	NA	V	NA
src/App.css / 43	NA	NA	NA	V	NA
src/App.tsx / 14	NA	NA	NA	V	P
src/components/Footer.tsx / 11	NA	NA	NA	V	P
src/components/HeroComet.tsx / 125	NA	NA	NA	V	P
src/components/Navbar.tsx / 59	NA	NA	NA	V	P
src/components/ProjectCover.tsx / 15	NA	NA	NA	V	P
src/components/ProjectGallery.tsx / 45	NA	NA	NA	V	P

Arquivo / linhas	T	A	I	S	X
src/components/ProjectModal.tsx / 59	NA	NA	NA	V	P
src/components/Reveal.tsx / 10	NA	NA	NA	V	P
src/components/SiteProcessModal.tsx / 67	NA	NA	NA	V	P
src/components/ThemeToggle.tsx / 27	NA	NA	NA	V	P
src/components/dialogKeyboard.ts / 15	NA	NA	NA	V	P
src/data/portfolio.ts / 131	NA	NA	NA	V	P
src/data/projectGallery.ts / 50	NA	NA	NA	V	P
src/data/siteProcess.ts / 70	NA	NA	NA	V	P
src/index.css / 300	NA	NA	NA	V	NA
src/main.tsx / 11	NA	NA	NA	V	P
src/project-showcase.css / 148	NA	NA	NA	V	NA
src/sections/About.tsx / 10	NA	NA	NA	V	P
src/sections/Approach.tsx / 10	NA	NA	NA	V	P
src/sections/Contact.tsx / 26	NA	NA	NA	V	P
src/sections/FeaturedProject.tsx / 60	NA	NA	NA	V	P
src/sections/Hero.tsx / 38	NA	NA	NA	V	P
src/sections/ProjectShowcase.tsx / 70	NA	NA	NA	V	P
src/sections/Projects.tsx / 25	NA	NA	NA	V	P
src/sections/Trajectory.tsx / 19	NA	NA	NA	V	P
src/site-process.css / 46	NA	NA	NA	V	NA
tailwind.config.js / 28	NA	NA	NA	V	NA
tsconfig.app.json / 29	NA	NA	NA	V	NA
tsconfig.json / 8	NA	NA	NA	V	NA
tsconfig.node.json / 27	NA	NA	NA	V	NA
vite.config.ts / 8	NA	NA	NA	V	NA

Os arquivos binários não recebem status V de ausência de segredos: apenas integridade por hash foi registrada. Ver varredura-segredos.json.

ISSUES PARA O GITHUB

Nenhuma issue de vulnerabilidade foi gerada porque não há achados confirmados. As recomendações preventivas e lacunas de verificação permanecem separadas.

```
--- ISSUES ---
0 achados confirmados nas cinco categorias.
Nenhuma issue para publicar.
--- FIM ISSUES ---
```

O mesmo conteúdo está disponível em issues-github.md. Não houve publicação automática.

Fontes e procedimento

React - elementos DOM e riscos de HTML bruto

https://react.dev/reference/react-dom/components/common#dangerously-setting-the-inner-html

Procedimento local da skill auditoria-seguranca-codigo

C:/Users/skate/.codex/skills/auditoria-seguranca-codigo/references/procedimento.md

Aceitação e próximos passos

A avaliação humana e a autorização de publicação continuam com o responsável pelo projeto. Mudanças no backend, nas integrações ou nas fontes de conteúdo exigem nova revisão proporcional ao risco.